

Checklist trước khi lên production/mainnet thật (Bước 4, mục 12)

Áp dụng cho đề tài "Hệ thống quản lý thuê nhà bằng smart contract". Đây là **tình trạng thật** tại thời điểm bàn giao đồ án — mục nào chưa làm được ghi rõ ❌ và giải thích lý do, **không đánh dấu ✓ giả**.

1. Smart contract

Hạng mục	Trạng thái	Ghi chú
Unit test cho toàn bộ luồng nghiệp vụ chính	✅ Đã làm	32 test (<code>test/RentalManager.test.ts</code>): đăng tin, huỷ tin, đặt cọc, trả tiền (kèm phạt trễ), bàn giao, đề xuất/đồng ý/khiếu nại/trọng tài bỏ phiếu (multisig), CID ảnh IPFS, các trường hợp bị chặn, token đại diện hợp đồng.
Test bảo mật riêng (reentrancy, transfer bị chặn)	✅ Đã làm	Test cả 2 overload <code>safeTransferFrom</code> bị chặn; test contract độc hại cố gọi lại <code>rentProperty</code> trong <code>onERC721Received</code> , xác nhận <code>nonReentrant</code> chặn được.
Checks-effects-interactions cho mọi hàm chuyển ETH	✅ Đã làm	<code>rentProperty</code> , <code>payRent</code> , <code>acceptSettlement</code> , <code>voteOnDispute</code> — state cập nhật trước, gọi ngoài sau.
Custom error thay vì string revert (tiết kiệm gas)	⚠️ Một phần	<code>RentalAgreementToken</code> dùng custom error; <code>RentalManager</code> vẫn dùng <code>require(..., "string")</code> cho các rule nghiệp vụ chính — chưa đổi vì đổi sẽ ảnh hưởng đến các <code>revertedWith(...)</code> hiện có trong frontend/test, không cấp bách cho phạm vi đồ án.
Static analysis tự động (Slither)	❌ Chưa chạy được	Gặp lỗi tương thích <code>cryptic-compile</code> với định dạng build-info của Hardhat 3, và lỗi resolve import của bản <code>solc</code> native trên đường dẫn có Unicode — xem chi tiết và rà soát thủ công thay thế tại docs/bao-mat-slither.md .
Fuzz / invariant test (Foundry)	❌ Chưa làm	Không cài Foundry trong lần này (quyết định phạm vi — xem plan: tốn thời gian cài đặt trên Windows không tương xứng lợi ích cho một đồ án). Cần làm trước khi lên mainnet thật.
Audit độc lập bên ngoài (bên thứ ba/giảng viên rà soát)	❌ Chưa có	Đây là việc con người phải tự thực hiện (giảng viên/nhóm/bên kiểm toán độc lập), không phải việc code có thể tự làm thay. Rà soát thủ công trong <code>docs/bao-mat-slither.md</code> không thay thế được một audit thật.
Cơ chế tạm dừng khẩn cấp (<code>Pausable</code>)	❌ Chưa có	Nếu phát hiện lỗi nghiêm trọng sau khi deploy, hiện không có cách nào tạm dừng hệ thống. Cần thêm <code>Pausable</code> + vai trò <code>PAUSER_ROLE</code> trước production thật.
Quản trị admin bằng multisig	❌ Chưa có	<code>DEFAULT_ADMIN_ROLE</code> của cả <code>RentalAgreementToken</code> lẫn <code>RentalManager</code> hiện là một địa chỉ EOA đơn (ví deploy) — rủi ro tập trung quyền lực nếu khoá bị lộ (kẻ tấn công có thể tự cấp <code>ARBITER_ROLE</code> cho mình). Production thật nên chuyển admin sang ví multisig (vd Safe).
Time lock cho quyết định trọng tài	❌ Chưa có	<code>voteOnDispute</code> thực thi tất toán ngay khi đủ phiếu, không có độ trễ để bên còn lại phản ứng nếu trọng tài thông đồng — xem gioi-han-va-rui-ro.md § 4 .

2. Backend / hạ tầng

Hạng mục	Trạng thái	Ghi chú
Event indexer đọc on-chain, ghi lại off-chain để tra cứu nhanh	✅ Đã làm	<code>backend/src/indexer.ts</code> — quét theo cursor, chờ <code>CONFIRMATIONS</code> , idempotent.
REST API tra cứu	✅ Đã làm	<code>backend/src/server.ts</code> — <code>/health</code> , <code>/api/properties</code> , <code>/api/properties/:id</code> , <code>/api/history/:id</code> .
Database production-grade (đa kết nối đồng thời)	❌ Chưa có	Đang dùng SQLite (<code>node:sqlite</code>) — phù hợp demo/đồ án, không phù hợp production nhiều tiến trình ghi đồng thời. Cần chuyển sang PostgreSQL (đổi driver, schema tương đương) — xem <code>backend/README.md</code> .
Cơ chế đối soát khi reorg sâu	❌ Chưa có	Chỉ giảm thiểu bằng <code>CONFIRMATIONS</code> , chưa có reconciliation job riêng khi phát hiện lệch dữ liệu.
Bí mật (RPC key, private key) không nằm trong code/git	✅ Đã làm	Root project dùng Hardhat keystore (không còn dotenv cho secret khi deploy Sepolia); <code>backend/.env</code> nằm trong <code>.gitignore</code> .
Giám sát/logging tập trung (production monitoring)	❌ Chưa có	Hiện chỉ log ra console. Production thật cần structured logging + alerting.

3. Vận hành / pháp lý (ngoài phạm vi code)

Hạng mục	Trạng thái	Ghi chú
Giá trị pháp lý của "hợp đồng thuê" on-chain	❌ Ngoài phạm vi	Token <code>RentalAgreementToken</code> chỉ là bằng chứng kỹ thuật số trên chain, không tự động có giá trị pháp lý ngoài đời — cần văn bản giấy/điện tử có chữ ký kèm theo trong triển khai thật.
Trọng tài thật ngoài đời (con người) cho <code>ARBITER_ROLE</code>	❌ Ngoài phạm vi	Contract chỉ cung cấp cơ chế bỏ phiếu on-chain; việc tìm/chỉ định người/tổ chức đóng vai trò trọng tài đáng tin cậy ngoài đời là việc vận hành, không phải việc code.

4. Kết luận

Các hạng mục ❌ ở trên là **giới hạn đã biết của phạm vi đồ án**, không phải sai sót bị bỏ sót ngoài ý muốn. Trước khi đưa hệ thống này ra vận hành với tiền thật trên mainnet, bắt buộc phải hoàn thành ít nhất: Slither/static-analysis chạy được, audit độc lập, cơ chế `Pausable` , và multisig cho admin.